

御网智元

可审计的通用网络安全智能体
初审冲刺材料 | 仅授权附件与 localhost

证据：技术报告；官方赛题资料（2026-08-28）

初审回答的问题

复杂任务如何自主规划？
如何约束工具与授权？
如何证明成功不是模型自述？

证据：官方五维评分口径；差距矩阵

可审计闭环

正式 HTTP 消息 -> Run 快照 -> AgentEngine -> 受控工具 ->
Artifact/事件 -> 独立 Judge

证据: FastAPI、SQLite、ToolSpec/Registry/Executor

不可变 Run 快照

冻结 Provider、Agent、授权、工具、目标和附件。
轨迹、报告与评测索引关联同一 Run。

证据：TaskSpec、Run、Artifact、ExecutionStep、Evidence

黄金案例绑定

case_id + case_version + 目标/请求/附件 SHA-256 + 授权摘要
+ 工具快照摘要。
相似 Run 不匹配即拒绝评分。

证据：GoldenCaseBinding；未绑定 Run 拒绝回归

案例 A：最终验证闭环

Agent 必须真实调用 FlagCandidateVerifyTool。
未调用即拒绝完成并回到重规划；Judge 核验候选哈希与工具结果。

案例 B：本地 Web 线索

仅允许 localhost 与冻结 URL 范围。
按动态线索选择受控 HTTP 证据和解析工具。

证据：B manifest；本地 Web lab；解码链证据

案例 C：注入后安全恢复

先识别并拒绝注入影响；再用附件检查工具完成授权摘要。
不补写 safety.recovered，摘要绑定真实工具证据。

证据：C manifest；注入安全回归

解释与复现

公开事件、参数摘要、Artifact 引用和 Judge 理由组成可追溯路径。

Judge 配置不进入 Agent Prompt。

工具协同与扩展

ToolSpec/Registry/Executor 统一输入、风险、超时和审计契约。
内置、插件与 MCP 遵循同一边界。

证据：工具契约测试；风险审批策略

上传安全与工作台

CSV、ZIP、TAR 均有条目、展开量、压缩比和解析复杂度限额。
真实工作台显示脱敏状态，不含密钥。



证据：拒绝测试；Playwright 桌面截图

移动端可用性

移动端保持场景选择、授权前置与安全边界入口；不以占位页替代实际界面。



证据：Playwright 移动端截图

工程与供应链

Docker 全新构建、健康检查、隔离黄金卷、启停诊断脚本。
生产与完整 npm audit 均为 0 漏洞。

证据: full-check; audit JSON; undici 7.29.0

真实评测口径

真实 Provider 三次评测是必需项。独立黄金卷未配置 Provider/Agent，故未填写 pass@1、成本或 Token。

证据：/setup/status；测试与评测报告

边界与提交

不做任意 Shell、公网攻击、外部平台提交或伪造成绩。
配置真实 Provider 后按同一证据链补齐三次数据。

证据：证据矩阵；部署/用户手册；签章占位